IA ataca con un modelo local, IA defiende con Security Copilot

Jorge Castañeda

Microsoft MVP Security

Microsoft 365 Live 4 al 8 de Noviembre del 2026

#M365live

100% Online y gratis

Microsoft 365 LIVE 2026

APERTURA

Un pentest autónomo con IA ya apareció en brechas reales

AhnLab ASEC, octubre de 2026. Corea del Sur y Japón.

¿Y si la IA también ataca tu tenant?



Sobre mí



Jorge Castañeda

Solution Architect Security, Readymind

- Microsoft MVP Security
- Solution Architect Security en Readymind, Lima, Perú
- Construyo Agent Zero Labs: ataques reproducibles contra agentes de IA

Redes sociales:

blog.d3fend.me

https://me.d3fend.me/

La IA propone, el código pone las puertas, una persona decide.

Jorge Castañeda

ARROW TD SYNNEX V-Valley CMConsulting

CONTEXTO

Por qué importa ahora

Tres señales recientes, con fuente

LLMjacking

Más de 100 000 USD en un día; hasta 1 millón antes de revocar el acceso.

GTIG y Mandiant, 2 nov 2026

Agentes atacantes

ARTEX y PentAGI aparecen en intrusiones reales desde fines de agosto.

GTIG y Mandiant, 30 oct 2026

ATT&CK cambió

Desde la v19 son 15 tácticas: Defense Evasion se partió en Stealth y Defense Impairment.

MITRE ATT&CK v19 y v20

Agenda de la sesión



Exposición

Blackbriar: ¿qué podría pasar?



Contraste

Copilot: ¿qué puede demostrar?



Investigación

Outcome: ¿qué ocurrió?

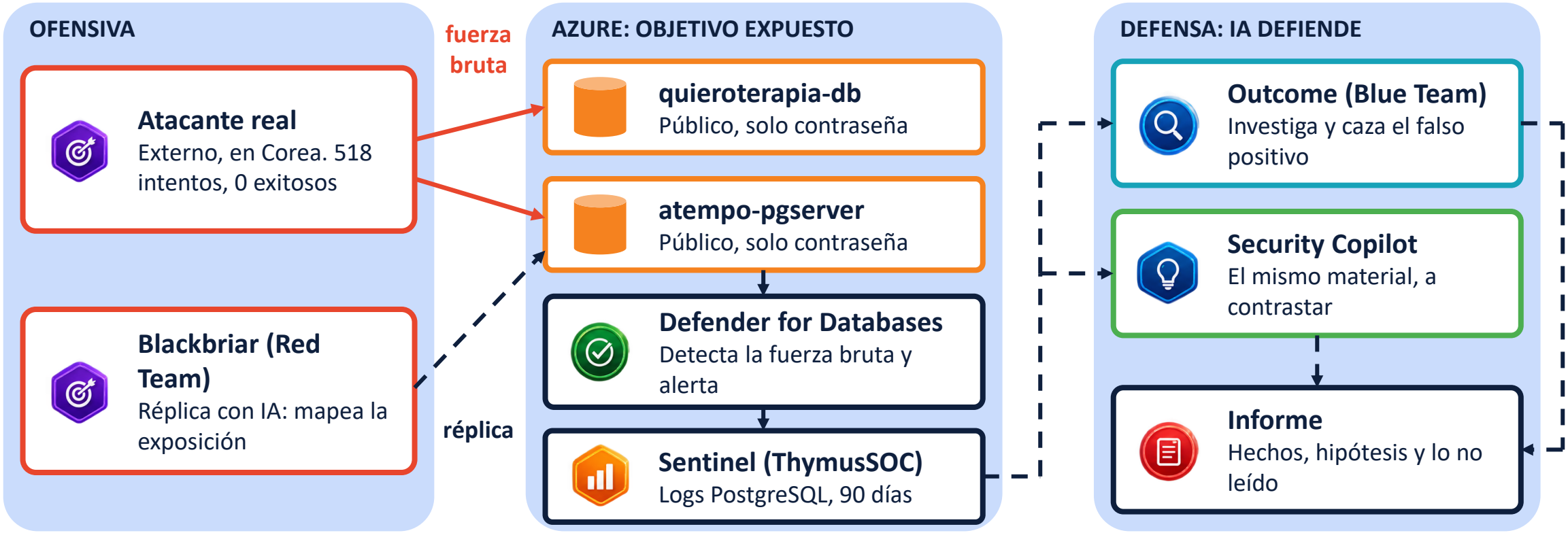


Decisión

Qué autorizas y qué harás mañana

Caso PostgreSQL: un incidente, tres miradas

PostgreSQL expuesto. Una alerta. ¿Qué podemos demostrar?



Línea roja: ataque real. **Línea punteada: réplica y telemetría.** Borde azul marino: servicio de Microsoft.

Microsoft 365 LIVE 2026

BLOQUE 1

Blackbriar busca la exposición

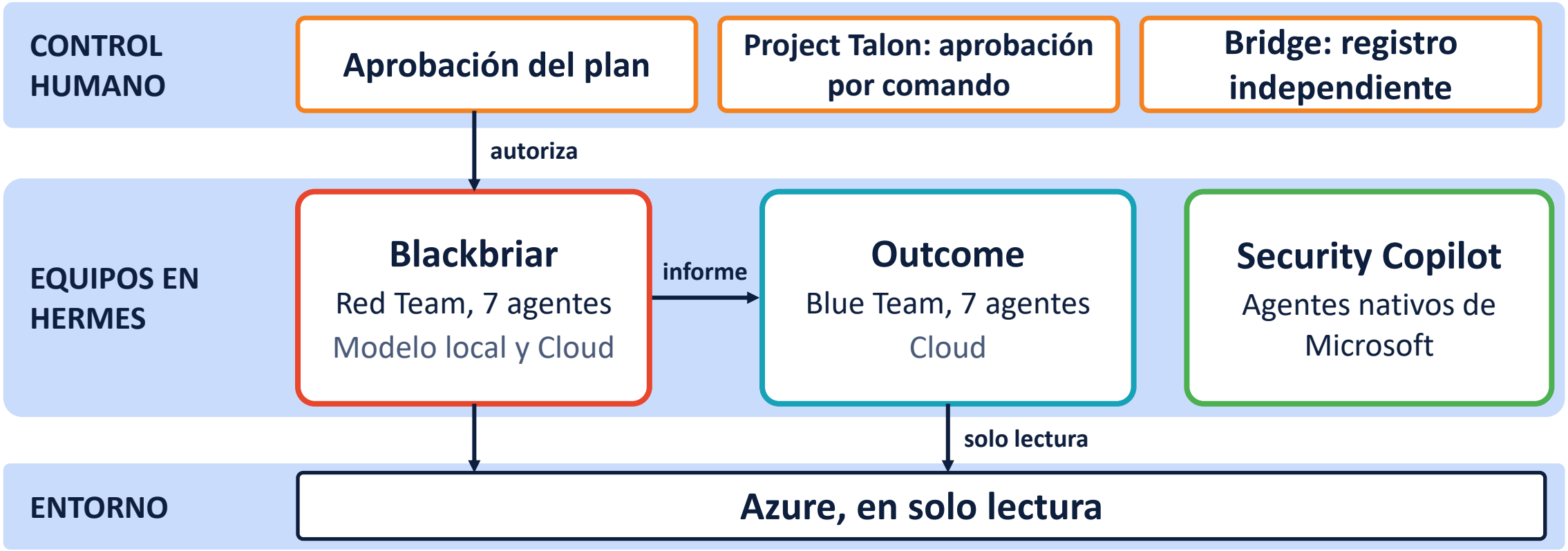
¿Qué podría aprovechar un atacante?



ARROW TD SYNNEX V-Valley CMConsulting

BLOQUE 1

Arquitectura en tres planos



BLOQUE 1

Cinco controles en capas

Ninguno depende de que el modelo se porte bien

1. **Deny by default** Nada corre si no está permitido de antemano: objetivos y acciones, en lista cerrada.
2. **Catálogo cerrado** Solo comandos de un catálogo: nmap, Metasploit (módulos fijos), nuclei, sqlmap.
3. **Aprobación por acción** Cada comando se aprueba aparte, viendo el comando exacto antes de que corra.
4. **Re-verificación** El bridge comprueba que lo que corre es lo aprobado; si el plan cambió, lo rechaza.
5. **Kill switch y freno** Una parada de emergencia que cancela, y una pausa que se puede revertir.



DEMO 1

Blackbriar: exposición de PostgreSQL

Qué observar

La exposición y sus evidencias

Una prueba con aprobación propia

Qué no pudo verificar

BLOQUE 1

Qué encontró y qué no

Corrida histórica v8 del 3 de nov. Nada se ejecutó.

Hechos

- Rol que actualiza credenciales de apps
- MFA de admins solo en modo informe
- Contenedores con red pública y PostgreSQL sin Entra-only

Hipótesis

- Un rol que cambia credenciales de apps, sin MFA impuesto, podría permitir escalar privilegios
- Sin confirmar

Lo que no se leyó

- RBAC de Azure e identidad administrada compartida: ninguna consulta los pidió
- Ámbito del rol: la lectura falló

Escenarios

- 6 propuestos, con 6 técnicas MITRE ATT&CK
- Nada corrió: una persona aprueba cada paso

BLOQUE 2

Outcome investiga el mismo caso

¿Qué ocurrió y qué evidencia lo demuestra?



BLOQUE 2

Del Red al Blue: inyección de prompt

Una IA ofensiva alimenta a una IA defensiva: el código pone las puertas

Informe de Blackbriar
Generado por IA. Se trata como dato.

→

Bunga
Único paso que recibe el texto crudo, como dato.

→

Respuesta validada
Estructurada: hechos, hipótesis y huecos.

→

Anga a Kion
Solo reciben respuestas validadas.

Material es dato

Sin datos, severidad desconocida

Validación cruzada de 22 reglas

DEMO 2

Outcome investiga el incidente 5154

Qué observar

El incidente y sus evidencias

Intentos frente a accesos exitosos

La etiqueta que exige contraste

EL GIRO DEL CASO

La evidencia cambia la lectura de la alerta

Incidente 5154 y campaña PostgreSQL, octubre de 2026

Lo observado

518 intentos fallidos y 0 exitosos en la campaña completa.

La alerta del 22 de octubre registra 140 fallidos y 0 exitosos.

Lo que cambió

La etiqueta de manipulación de logs era un falso positivo.

Una regla de automatización de Sentinel mal acotada la añadió.

La evidencia del caso no muestra accesos exitosos.

Intentos sin acceso exitoso

Etiqueta sin borrado real

Decisión con evidencia

BLOQUE 3

Security Copilot, otra mirada

Mismo incidente, mismos criterios de evidencia



BLOQUE 3

Dónde encaja Security Copilot

Agentes nativos en Defender

Dynamic Threat Detection

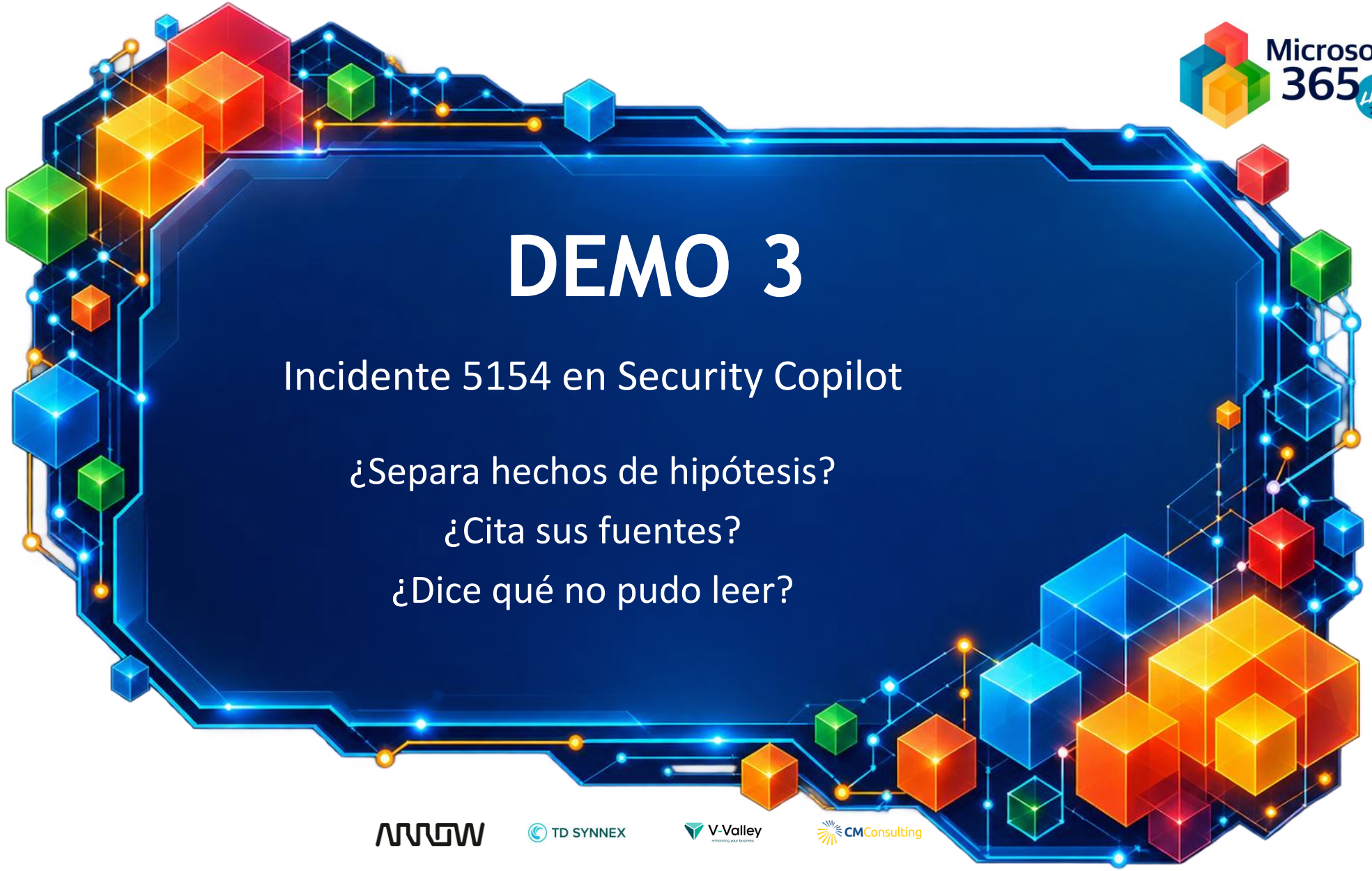
Correlaciona alertas, eventos y threat intel en segundo plano.

Security Analyst

Analiza patrones y entrega un rastro de evidencia completo.

Threat Hunting

Traduce lenguaje natural a consultas KQL.


DEMO 3
Incidente 5154 en Security Copilot
¿Separa hechos de hipótesis?
¿Cita sus fuentes?
¿Dice qué no pudo leer?

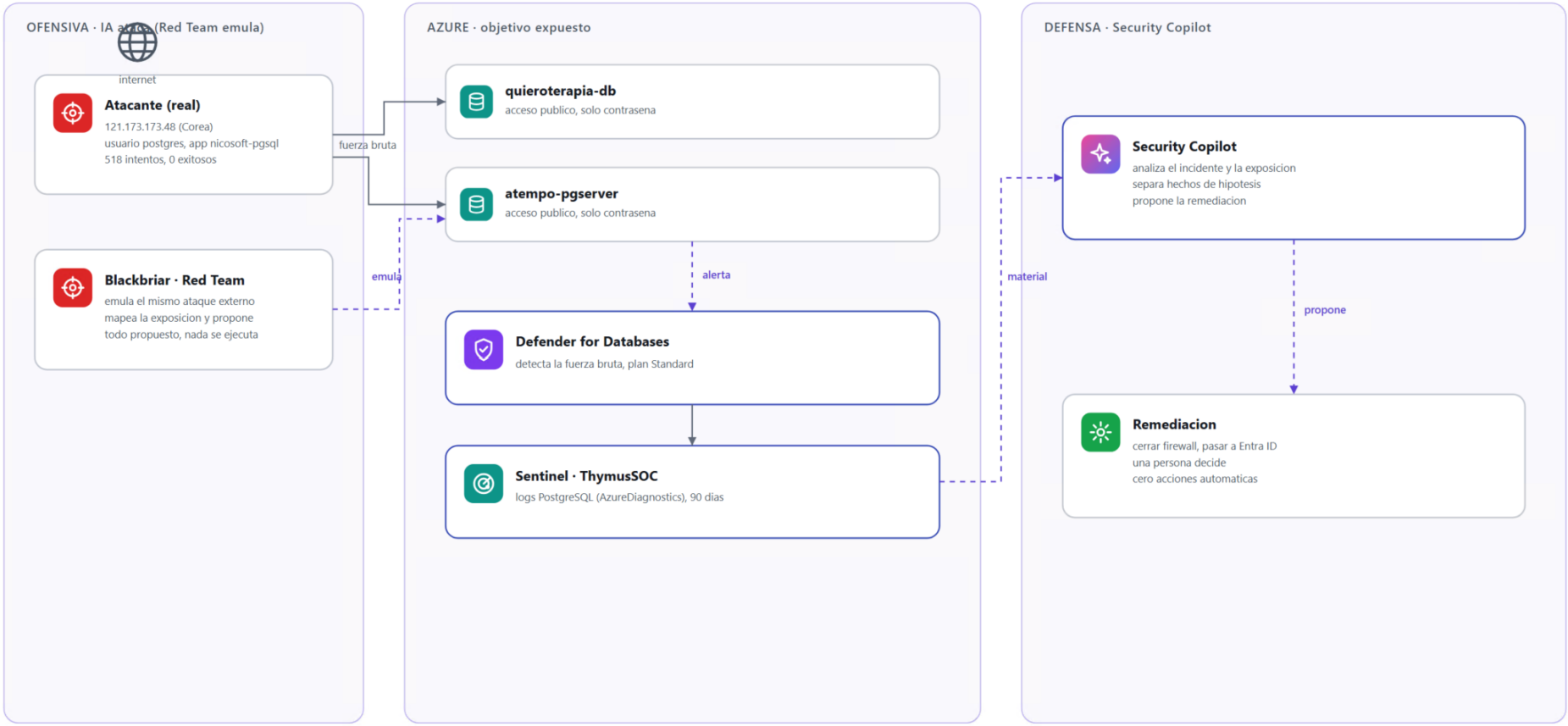
BLOQUE 2

Security Copilot: qué le entrega a un analista N1

Para que el N1 actúe	Security Copilot
Hechos vs. hipótesis	Separados: seguro para actuar
Fuente de cada hecho	Sí, con su fuente
Qué no pudo leer	Lista honesta de lo que falta
Qué requiere aprobación	Marcado: cambia el recurso
Dónde y qué tan rápido	En el portal de Defender, en minutos

CASO DE USO · Arquitectura: un ataque real, dos lados

IA ataca (atacante real + Blackbriar/Red Team) -> objetivo expuesto (PostgreSQL) -> Security Copilot analiza y propone la remediación



FLUJO · Cómo se alerta y previene un caso similar

Del incidente a una decisión de primer nivel, en minutos. El agente investiga, una persona decide, cero acciones automáticas.



CIERRE

Límites y riesgo residual

Qué puede demostrar el laboratorio y qué queda por verificar

1. El bridge verifica qué herramientas llamó cada agente, no lo que devolvieron: las conclusiones las escribe el agente.
2. Lo que se pega y lo que devuelve cada paso de Outcome viaja a GitHub Copilot.
3. Los modelos se equivocan: Shenzi propuso escenarios inválidos y Scar los descartó.
4. Un solo tenant y pocas corridas: evidencia de un laboratorio, no una medición general.
5. Aprobar sin leer anula el control: la fatiga de aprobaciones es un riesgo (NIST NCCoE).

LA DECISIÓN

El humano decide

¿Qué evidencia necesitas antes de autorizar una acción?

Pedir permiso antes

Aprobación por acción: ves el comando exacto antes de que corra. En tu consola, un nmap se aprobó 3 segundos después de pedirse.

Detener ahora

Kill switch: parada de emergencia que cancela. Freno: pausa que se puede revertir. El mercado ya lo nombra: AI Kill Switch de CrowdStrike, 3 de noviembre.

Aprobar sin leer no es control: la fatiga de aprobaciones es un riesgo documentado (NIST NCCoE).

Tu turno: ¿qué autorizarías y qué evidencia pedirías antes?

CIERRE

Tres ideas para probar mañana

Tu próximo paso como analista



Inventaría tus agentes

Trátalos como identidades privilegiadas: dueño, permisos y credenciales.

Empieza por la tabla AgentsInfo en advanced hunting.



Verifica con otra fuente

Separa hechos de hipótesis y contrasta con algo que el agente no controla.

Por ejemplo, los registros de actividad de Microsoft Graph.



Aprueba donde pesa

Pide aprobación por acción sensible, no por cada clic.

Mide cuántas aprobaciones se dan sin leer.

CIERRE

Recursos para seguir

Para repetirlo y para leer las fuentes

Para repetirlo

github.com/jcastanedacano/agent-zero

agentic.d3fend.me

Marcos y fuentes

MAESTRO (CSA): modelo de amenazas

MITRE ATT&CK y ATLAS

NIST NCCoE, GTIG y Mandiant, AhnLab

#M365Live #Microsoft365Live2026

[contacto pendiente]

BLOQUE 2

El humano decide

Dos controles distintos, y una advertencia

Pedir permiso antes

Aprobación por acción: ves el comando exacto antes de que corra. En tu consola, un nmap se aprobó 3 segundos después de pedirse.

Detener ahora

Kill switch: parada de emergencia que cancela. Freno: pausa que se puede revertir. El mercado ya lo nombra: AI Kill Switch de CrowdStrike, 3 de noviembre.

Aprobar sin leer no es control: la fatiga de aprobaciones es un riesgo documentado (NIST NCCoE).

Tu turno: ¿cuál de los dos escenarios de prioridad alta validarías primero?

CIERRE

Límites y riesgo residual

Qué no hace, qué falla y qué se acepta [contrastar con RIESGO_RESIDUAL.md]

1. El bridge verifica qué herramientas llamó cada agente, no lo que devolvieron: las conclusiones las escribe el agente.
2. Lo que se pega y lo que analiza Security Copilot viaja a los servicios de IA de Microsoft.
3. Los modelos se equivocan: Shenzi propuso escenarios inválidos y Scar los descartó.
4. Un solo tenant y pocas corridas: evidencia de un laboratorio, no una medición general.
5. Aprobar sin leer anula el control: la fatiga de aprobaciones es un riesgo (NIST NCCoE).

CIERRE

Tres ideas para probar mañana

Qué puedes hacer mañana por la mañana



Inventaría tus agentes

Trátalos como identidades privilegiadas: dueño, permisos y credenciales.

Empieza por la tabla AgentsInfo en advanced hunting.



Verifica con otra fuente

Separa hechos de hipótesis y contrasta con algo que el agente no controla.

Por ejemplo, los registros de actividad de Microsoft Graph.



Aprueba donde pesa

Pide aprobación por acción sensible, no por cada clic.

Mide cuántas aprobaciones se dan sin leer.

CIERRE

Recursos para seguir

Para repetirlo y para leer las fuentes

Para repetirlo

github.com/jcastanedacano/agent-zero

range.d3fend.me

agentic.d3fend.me

Marcos y fuentes

MAESTRO (CSA): modelo de amenazas

MITRE ATT&CK y ATLAS

NIST NCCoE, GTIG y Mandiant, AhnLab

#M365Live #Microsoft365Live2026

[contacto pendiente]

Preguntas

La IA propone. Una persona decide.

Preguntas del chat

#M365Live

Canal: Somos Lulo TV

Gracias

Nos vemos en la comunidad.
Comparte la sesión y sigue la conversación con #M365Live

Jorge Castañeda

[correo pendiente]

[usuario pendiente]

[LinkedIn pendiente]



PATROCINADORES

Gracias a nuestros patrocinadores

Gracias a quienes hacen posible que esto sea gratis y en abierto.

Microsoft 365 LIVE 2026

ARROW

TD SYNNEX

CMConsulting

V-Valley
enhancing your business